

PHISHING EMAIL DETECTION & AWARENESS REPORT

Future Interns — Task 2: Cybersecurity

Prepared By

Maanas Sri Udbhav Maddula

Domain

Cybersecurity

Date

18 June 2026

1. Introduction

Phishing is still one of the easiest ways for attackers to get inside an organization, and that's exactly why it remains so common. Rather than breaking through technical defenses, attackers go after people directly — sending deceptive emails, building fake login pages, and attaching malicious files, all designed to trick someone into handing over a password, a bank detail, or a moment of trust.

This project set out to look at that problem up close. The goal was to analyze a set of real phishing email samples, work out what gave each one away, sort them by how dangerous they actually were, and turn those findings into awareness guidance that an organization could realistically use.

In practice, the work mirrored what a Security Operations Center (SOC) analyst does day to day: receiving a suspicious email, picking it apart, and deciding whether it's a genuine threat.

2. Objectives

The task was built around a few clear goals:

- Analyze a range of suspicious email samples.
- Examine email headers and sender information in detail.
- Identify the indicators that point to phishing.
- Classify each email by risk level.
- Investigate the links, domains, and attachments involved.
- Document the findings in a clear, professional way.
- Translate the findings into practical security awareness recommendations.

3. Tools Used

A mix of email analysis, investigation, and documentation tools supported the work:

Category	Tools
Email Analysis	Mozilla Thunderbird, Google Message Header Analyzer, MXToolbox Header Analyzer, Cisco Talos Intelligence
Investigation Platforms	TryHackMe SOC Simulator, Splunk SIEM, Threat Intelligence Sources
Documentation	Microsoft Word, GitHub

4. Methodology

Each email went through the same step-by-step process, which kept the analysis consistent across very different cases:

1. Collect phishing email samples.
2. Review the email content and subject line.
3. Analyze sender information.
4. Examine the email headers.
5. Validate SPF, DKIM, and DMARC records.
6. Inspect embedded links and attachments.
7. Check domain reputation.
8. Identify phishing indicators.
9. Classify the risk level.
10. Document the findings and recommendations.

5. Case Study 1 – Inheritance Scam Email

Subject	Inheritance Alert: Unknown Billionaire Relative Left You Their Hat Fortunes
Sender	eileen@trendymillineryco.me
Recipient	support@tryhackme.com

This email claimed that a wealthy, unknown relative had left the recipient an inheritance, and asked for banking details to “release the funds.” It's a familiar scam dressed up in slightly absurd detail — the “hat fortune” framing — but the underlying mechanics are the same ones used in inheritance and lottery scams for decades.

Indicators Identified

- An unexpected inheritance claim out of nowhere.
- A vague, generic financial “opportunity.”
- A request for banking details.
- Classic social engineering pressure.
- A sender domain that doesn't hold up to scrutiny.
- A financial reward that's simply too good to be real.

Risk Classification: High Risk

Verdict: *Confirmed Phishing Email*

Awareness Tip — No legitimate inheritance, estate, or legal process ever needs your bank details sent over email. If a message promises sudden money from a stranger, treat it as a scam and don't reply, click, or share any information.

datasource: email

timestamp: 06/18/2026 05:12:51.361

subject: Inheritance Alert: Unknown Billionaire Relative Left You Their

sender: eileen@trendymillineryco.me

recipient: support@tryhatme.com

attachment: None

content: A long lost billionaire relative has left you their secret hat em
immediately

direction: inbound

6. Case Study 2 – Malicious Invoice Attachment

Subject	FINAL NOTICE: Overdue Payment – Account Suspension Imminent
Sender	john@hatmakereurope.xyz
Attachment	ImportantInvoice-February.zip

Indicators Identified

- A ZIP file attached to the message.
- An urgent, overdue-payment storyline.
- An implied threat of legal action.
- A warning that the account would be suspended.
- A sender domain unrelated to any real biller.
- Heavy use of pressure tactics to rush the recipient.

Risk Classification: Critical Risk

Verdict: *Malicious Phishing Email*

This one carried real teeth: the email used urgency and the threat of legal trouble to push the recipient toward opening the attached ZIP file without thinking it through. Had it been opened, the likely outcomes include:

- Malware infection.
- Credential theft.
- Remote access compromise.
- Ransomware deployment.

Awareness Tip — Never open a ZIP, EXE, or other unexpected attachment just because an email sounds urgent. Verify overdue payment or invoice claims directly with the vendor through a known phone number or website before taking any action.

6/18/26 4:22:46.361 AM

[-]

attachment: ImportantInvoice-February.zip

content: URGENT: Your account is 30 days past due and will be suspended today unless immediate payment is processed. Legal action will commence if payment is not received within 24 hours. Open the attached invoice immediately to view payment options and avoid legal consequences.

datasource: email

direction: inbound

recipient: michael.ascot@tryhatme.com

sender: john@hatmakereurope.xyz

subject: FINAL NOTICE: Overdue Payment - Account Suspension Imminent

timestamp: 06/18/2026 05:22:46.361

Show as raw text

Type	Field	Value
Selected	host	10.10.95.194:8989
	source	eventcollector
	sourcetype	_json
Event	attachment	ImportantInvoice-February.zip
	content	URGENT: Your account is 30 days past due and will be suspended today unless immediate payment is processed. Legal action will commence if payment is not received within 24 hours. Open the attached invoice immediately to view payment options and avoid legal consequences.
	datasource	email
	direction	inbound
	recipient	michael.ascot@tryhatme.com
	sender	john@hatmakereurope.xyz

7. Case Study 3 – Fake Vacation Prize Scam

Subject line: “You've Won a Free Trip to Hat Wonderland.”

The message told the recipient they'd won an all-expenses-paid vacation, then asked for credit card details — ostensibly to “confirm” the prize. There was no contest the recipient had entered, and no way to verify the claim through any official channel.

Indicators Identified

- An unsolicited prize notification.
- A request for payment information to “claim” the prize.
- A reward that's too good to be true.
- Reliance on social engineering rather than fact.
- No legitimate way to verify the offer.

Risk Classification: High Risk

Verdict: *Confirmed Phishing Email*

Awareness Tip — Genuine prizes and giveaways never ask for credit card or payment details to be “released.” If you don't remember entering a contest, the safest move is to ignore and delete the message.

8. Case Study 4 – Netflix Account Suspension Phishing Email

Subject line: “Your Netflix Account is on Hold.” The email told the recipient their account had been suspended and asked them to verify payment information right away.

Visual Analysis

On the surface, this was a well-built email: genuine Netflix branding, a clean and professional layout, a payment-verification request, an urgent call-to-action button, and a suspension warning — all of it engineered to build trust and push for a fast reaction.

Header Analysis

The technical headers told a very different story than the visual design:

- SPF validation failed.
- No valid DKIM signature was present.
- DMARC verification failed.
- The return path pointed to postmaster@etekno.xyz — a domain with no connection to Netflix, and a clear sign of sender spoofing.

In short, the sender address visible to the recipient looked like Netflix, but the underlying headers revealed an entirely unrelated set of domains.

Threat Intelligence Findings

A further check using Cisco Talos Intelligence looked at the infrastructure behind the message:

Domain	google.com
Hostname	google.com
Mail Server	smtp.google.com
Web Reputation	Favorable
Blocklist Status	Not Listed

The email had passed through legitimate Google infrastructure, which on its own looked clean. But that's also exactly the point — attackers often piggyback on trusted services to improve their odds of landing in an inbox. Combined with the authentication failures and the domain mismatch, this was enough to confirm the message as fraudulent.

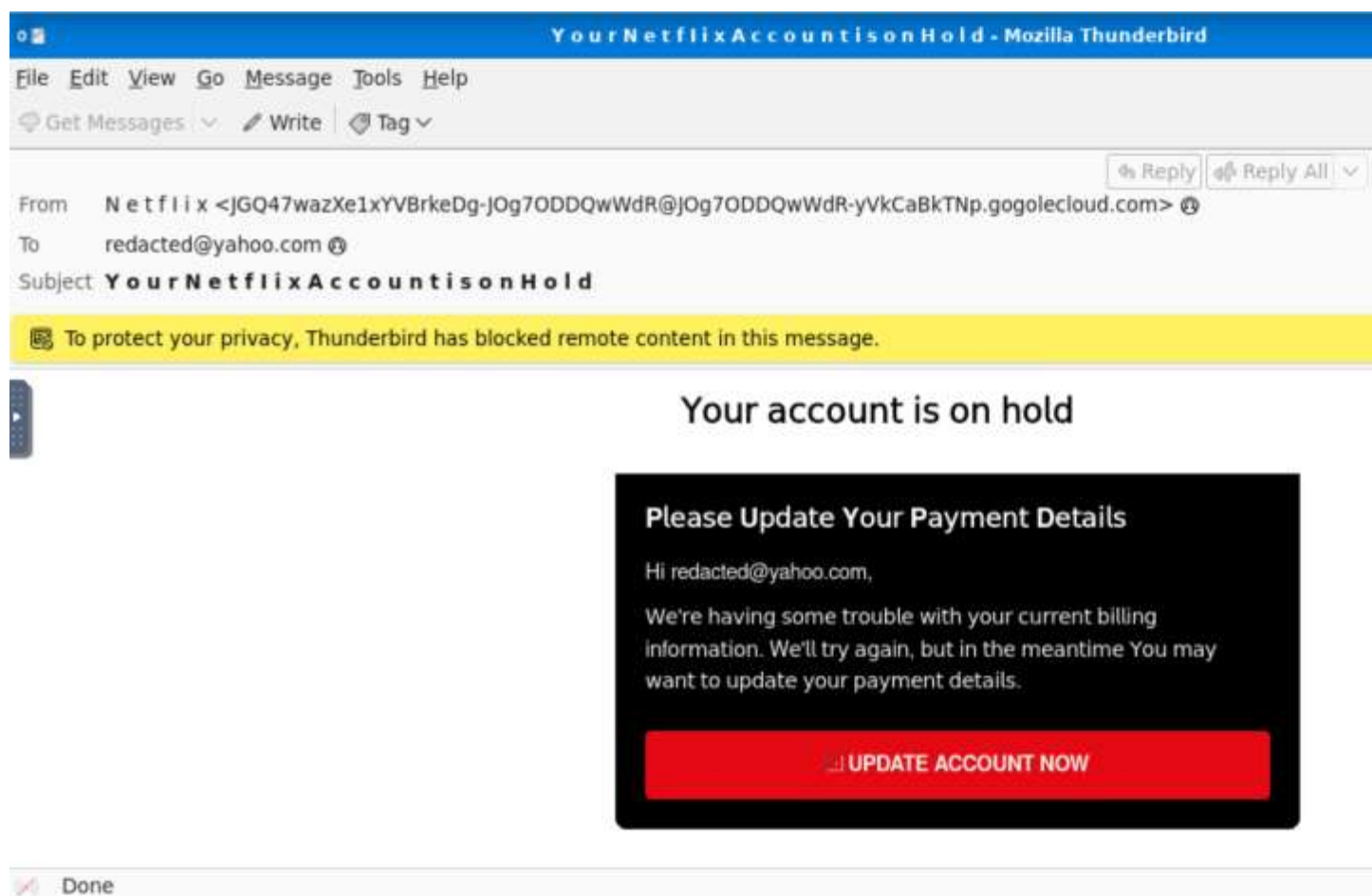
Indicators Identified

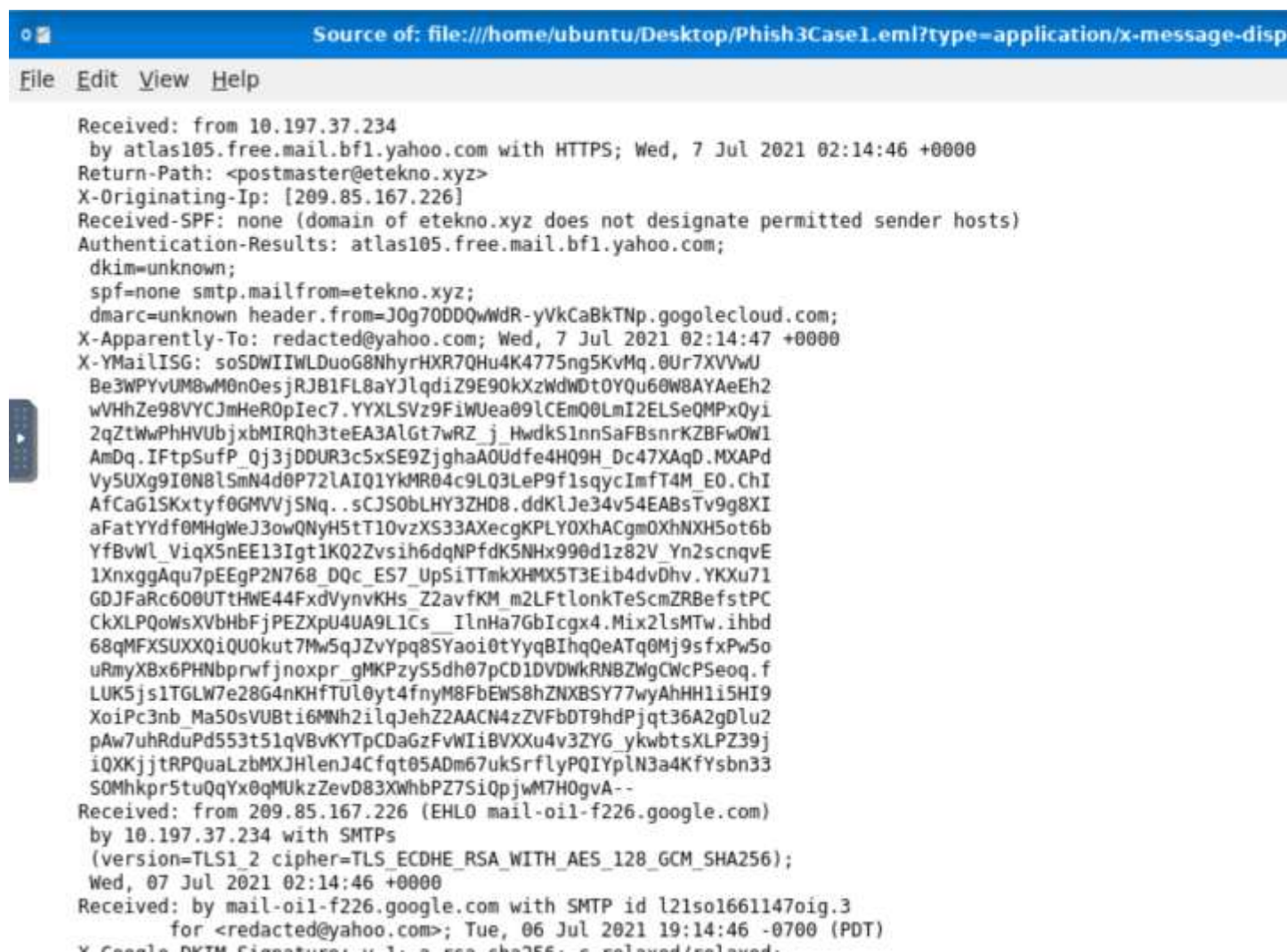
- Sender spoofing.
- A clear mismatch between the visible sender and the actual domain.
- SPF, DKIM, and DMARC all failing.
- An attempt to harvest credentials.

- Brand impersonation (Netflix).
- Urgency-driven language.
- A suspicious return-path domain.

Risk Classification: High Risk**Verdict:** *Confirmed Phishing Email*

Awareness Tip — Don't trust how an email looks — logos and formatting can be copied easily. Always go to the official app or website directly to check account status, and turn on Multi-Factor Authentication so a stolen password alone isn't enough to break in.





Case Study 5 – Blocked Malicious URL Investigation

Alert Name: Access to Blacklisted External URL Blocked by Firewall

Source IP: 10.20.2.17

Destination IP: 67.199.248.11

URL: <http://bit.ly/3sHkX3da12340>

Application: Web Browsing

Action: Blocked

Investigation Summary

During the investigation of a suspicious onboarding email, firewall logs generated an alert indicating that a user attempted to access a blacklisted external URL. The destination URL used a Bit.ly shortening service, a technique frequently used by attackers to conceal malicious destinations.

The firewall detected the connection attempt and automatically blocked the request before communication with the destination server could occur.

Indicators Identified

1. Use of a URL shortening service (Bit.ly).
2. Destination URL matched threat intelligence blacklist.
3. User interaction with suspicious email content.
4. Connection attempt to an external untrusted destination.
5. Correlation with a previously flagged phishing email.

Risk Classification

Risk Level: High

Classification: Confirmed Phishing Attempt

Potential Impact

If the firewall had not blocked the connection, the user could have been redirected to a phishing website designed to steal credentials, personal information, or financial data.

Potential consequences include:

- Credential theft
- Account compromise
- Malware infection
- Unauthorized access

Remediation Actions

- Block the malicious URL and associated domains.
- Verify whether the user submitted any information.
- Review endpoint activity for additional indicators.
- Continue monitoring for related phishing campaigns.
- Conduct user awareness training.

```
> 6/18/26      { [-]
4:53:46.953 AM  Action: blocked
                  Application: web-browsing
                  DestinationIP: 67.199.248.11
                  DestinationPort: 80
                  Protocol: TCP
                  Rule: Blocked Websites
                  SourceIP: 10.20.2.17
                  SourcePort: 34257
                  URL: http://bit.ly/3sHkX3da12340
                  datasource: firewall
                  timestamp: 06/18/2026 05:53:46.953
                }
Show as raw text
host = 10.10.241.216:8989 | source = eventcollector | sourcetype = _json
```

9. User Awareness Guidelines

A few simple habits go a long way toward keeping employees — and the organization — safe from phishing:

Do	Don't
Verify sender email addresses.	Open unexpected attachments.
Check domain names carefully.	Share passwords through email.
Inspect links before clicking.	Share OTPs or banking details.
Report suspicious emails immediately.	Click suspicious links.
Enable Multi-Factor Authentication (MFA).	Trust urgent requests without verification.
Verify requests through official channels.	

10. Common Phishing Indicators

Across all four cases, the same handful of warning signs kept showing up. Watching for these is often enough to catch a phishing attempt before any damage is done:

- Generic greetings instead of a real name.
- Urgent or threatening language.
- Warnings about account suspension.
- Offers of unexpected financial rewards.
- Misspelled or look-alike domains.
- Unexpected attachments.
- Requests for credentials.
- Requests for banking information.
- Fake login pages.
- Suspicious hyperlinks.

11. Recommendations

Based on these findings, organizations are better protected when they put the following in place:

- Ongoing security awareness training.
- Strong email filtering solutions.
- Properly configured SPF records.
- Properly configured DKIM records.
- DMARC enforcement.
- Endpoint protection.
- Regular phishing simulations.
- Multi-Factor Authentication across critical systems.

12. Conclusion

This project worked through phishing investigation and awareness building from the ground up, using four distinct scenarios — an inheritance scam, a malicious invoice attachment, a fake prize giveaway, and a Netflix credential-harvesting attempt — to cover the range of tactics attackers actually use.

By combining content analysis, header examination, domain reputation checks, and threat intelligence lookups, it was possible to pull out clear indicators in each case and rank them by how serious the risk actually was.

The bigger takeaway is straightforward: technical controls matter, but so does a workforce that knows what to look for. Awareness, solid email security configuration, and ongoing monitoring together form the strongest defense against phishing.